

1. REQUIREMENT RECAP

A summary of the requirements covered, and the demands of each.



IMPLEMENTATION

IMPLEMENTATION REQUIREMENT RECAP

Throughout the various requirements, we can detect some general patterns:

- The documentation and enforcement of security policies and procedures;
 - All areas.
- Proper change management processes
 - Related to changes in developed apps, user credential changes, firewall settings, other settings;
- The usage of common sense for certain definitions:
 - Cryptoperiod, patching periods, asset inventorying, etc;
 - Not so much the value, but having done diligence;
- Strong physical and logical security
 - Strong auth (MFA), strong encryption, key management;

IMPLEMENTATION REQUIREMENT RECAP

Let's quickly recap the 12 requirements covered:

1. Keep a Firewall;
2. No Defaults;
3. Protect Stored Data;
4. Protect Transmitted Data;
5. Prevent Malware;
6. Develop Securely;
7. Need-to-Know Access;
8. Identify Access;
9. Restrict Physical Access;
10. Log Everything;
11. Test Regularly;
12. InfoSec Policy;



IMPLEMENTATION REQUIREMENT RECAP



1. KEEP A FIREWALL

Requirement 1 is all about having a proper firewall configuration, restricting unknown traffic, having a firewall on all machines, and using change management.



3. PROTECT STORED DATA

Requirement 3 is about limiting CHD storage to the essential, purging it, masking PANs, having proper key encryption and key lifecycle management.



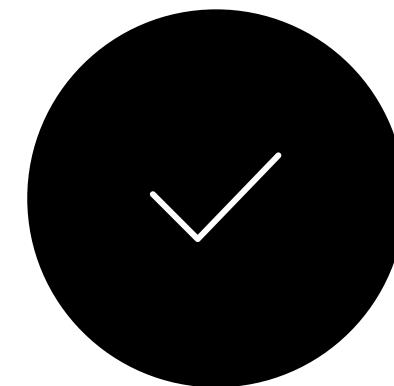
5. PREVENT MALWARE

Requirement 5 is about having proper AV software that is regularly updated, performs regular scans, outputs regular logs, and cannot be disabled individual users.



2. NO DEFAULTS

Requirement 2 is all about always changing default passwords and accounts, isolating servers, inventorying assets, and removing all unneeded functionality.



4. PROTECT TRANSMITTED DATA

Requirement 4 is all about protecting CHD in transit, including using strong encryption, including for public wireless networks, as well as never sending plaintext PANs.



6. DEVELOP SECURELY

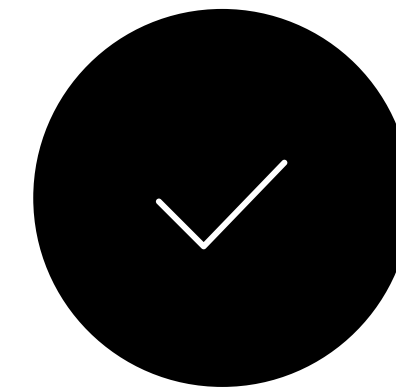
Requirement 6 is about securing both OTS software with risk ranking and patch installation, but also including security requirements in the SDLC and in dev training.

IMPLEMENTATION REQUIREMENT RECAP



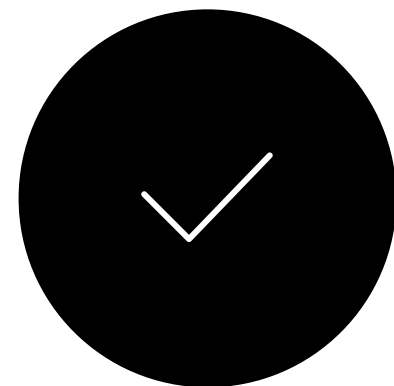
7. NEED-TO-KNOW ACCESS

Requirement 7 is all about the PoLP, or Principle of Least Privilege. Defining user roles with the least privilege possible, and using access control for systems/networks.



8. IDENTIFY ACCESS

Requirement 8 is about identifying specific users. Unique IDs, no shared users, strong authentication, MFA, not sharing physical access control devices, restricting DBs.



9. RESTRICT PHYSICAL ACCESS

Requirement 9 is about physical access. Entry control, visitor distinction and authorization, restricting physical access, and strict media storage/distribution, and training.



10. LOG EVERYTHING

Requirement 10 is about logging. Logging specific events and specific data elements, one time sync, log FIM, log retention, and immediate log alert responses.



11. TEST REGULARLY

Requirement 11 is about vulnerability scanning, penetration testing, AP identification (legit and rogue), IDS/IPS systems, and FIM/change detection.



12. INFOSEC POLICY

Requirement 12 is the sum of all policies. Usage policies, incident response, risk assessment, employee screening, employee roles, responsibilities, awareness and training.



IMPLEMENTATION

IMPLEMENTATION REQUIREMENT RECAP

Req. 1 (Keep a Firewall) is all about blocking access to the CDE through a firewall or other network security devices, and having clear rules for inbound/outbound traffic.

- Understanding the network topology and CHD data flows;
- Having firewalls, protective systems, good configurations;
- Also, minimizing traffic to the CDE to the essential;

Req. 2 (No Defaults) is, about not using defaults, such as vendor passwords, but more than that, it's about shutting down all obvious vulnerabilities;

- Not storing multiple functionality in one system;
- Disabling unnecessary features, ports, accounts;
- In short, not letting obvious vulnerabilities remain;

IMPLEMENTATION REQUIREMENT RECAP

Req. 3 (Protect Stored Data) is all about protecting stored card data at rest (truncating, tokenizing, encrypting, etc). The goal is that, even if the attacker obtains data, they can't see them:

- Effective key lifecycle (expiration, custodians) is required;
- Besides protecting data, minimizing the data you store also matters, as well as deleting data not needed anymore;

Req. 4 (Protect Transmitted Data) is simply about maintaining encryption of data when transmitting them in the the open:

- Strong authentication required (e.g., AES-256, 3DES);
- This not only includes WiFi but mobile, Bluetooth, or other communication modalities (WPA/WPA2 required);
- Never PANs as plaintext (masking them);





IMPLEMENTATION

IMPLEMENTATION REQUIREMENT RECAP

Req. 5 (Prevent Malware) is all about preventing malware from entering.

- Having anti-malware software, having it frequently updated, having it scan regularly, having it protect against all types of threats;
- Having policies so individual users can't disable it, too;

Req 6 (Develop Securely) is all about mitigating vulnerabilities in both in-house and third-party software:

- Secure SW dev lifecycle + patching vulnerabilities quickly;
- One of the hardest (devs don't care about security);
- Besides initial deployment of apps, changes must be managed (rollback policies, etc);

IMPLEMENTATION REQUIREMENT RECAP

Req. 7 (Need-to-Know Access) is all about restrictive access control, both digital and physical.

- “Least privilege”. Each role sees the least card data, for the least amount of time, to do their job. If possible, nothing!;
- Having access control by roles to formally enforce this;

Req. 8 (Identify Access) is all about non-repudiation and accountability. If something happens, the “associated human” must be identified.

- Unique IDs, no group users, removing old accounts;
- Strong password practices, account lockups on X attempts;
- Strong authentication measures unique to the person (fobs, smart cards, etc), MFA for certain actions (e.g., admin);





IMPLEMENTATION

IMPLEMENTATION REQUIREMENT RECAP

Req. 9 (Restrict Physical Access) is about limiting physical access to devices/people. CCTV, locked rooms, safes etc.

- Preventing both tampering with your devices (keyloggers, skimmers) or tampering with your people (social engineering);
- Also safe storage, transport, disposal of media w/ card data;

Req. 10 (Log Everything) is all about constant logging. If an attack occurs, we know when and where.

- Specific data must be stored, as well as specific events (actions on card data, admin actions, etc);;
- Time must be synchronized using one mechanism;
- FIM (File Integrity Management) on log files (no changes);

IMPLEMENTATION REQUIREMENT RECAP

Req. 11 (Test Regularly) is about regular testing networks and systems to identify vulnerabilities:

- Both internal and external. AP audit (legit + rogue), penetration testing, vulnerability scanning;
- Knowing what all of your weak points are - and regularly;

Req. 12 (InfoSec Policy) is about having pervasive policies, for all types of security controls, at all levels:

- Touches all roles, all systems, all levels dealing with CHD;
- Tech usage policies (what tech, acceptable use, rules);
- Employee screening. Yearly BG checks, NDAs on CHD;
- Formal incident management procedures, yearly tested;



IMPLEMENTATION REQUIREMENT RECAP EXAMPLES

/01 REQUIREMENTS 3 AND 4

Requirements 3 and 4 can be considered parallels, in a way. One is about securing stored CHD data, while the other is about securing transmitted data.

/02 REQUIREMENTS 7 AND 9

Requirement 7 and 9 are both about security. 7 is about access to logical data (need-to-know), while 9 is about access to physical data (media storage).

/03 REQUIREMENT 12

Requirement 12, forming a full-spectrum InfoSec policy, can almost be considered the sum of the “Document and Enforce Procedures” points of all reqs.

IMPLEMENTATION

REQUIREMENT RECAP

KEY TAKEAWAYS

/01 1 FIREWALL / 2 NO DEFAULT

Req 1 is about maintaining a strict firewall system to block unsecured traffic. Req 2 is about removing defaults and unneeded functionality of systems.

/03 5 MALWARE / 6 DEVEL.

Req 5 is about having AV to prevent malware attacks, while Req 6 is about having secure development practices and patching vulnerabilities.

/05 9 PHYSICAL / 10 LOGGING

Req 9 is about limiting physical access, including visitor management and physical media management, while 10 is about logging and alerts.

/02 3 STORED / 4 TRANSMITTED

Req 3 is about protecting stored data, while Req 4 is about protecting transmitted one. Both deal with strong encryption and masking PANs used.

/04 7 LIMIT / 8 IDENTIFY

Req 7 is about limiting logical access through “need-to-know” roles, while Req 8 is about identifying access. Unique IDs, strong authentication, MFA, etc.

/06 11 TEST / 12 POLICIES

Req 11 is about pentesting, vulnerability testing, IDS/IPS, while 12 is about the management policies of different areas throughout the organization.